

TSSR - Les aspects juridiques



DISCLAIMER

Ton formateur/ta formatrice n'est pas un.e juriste ni un.e professionnel.le du droit.

Ce cours est une approche juridique pour tout professionnel de l'IT en entreprise.

Le droit n'est pas un domaine figé et peut évoluer.

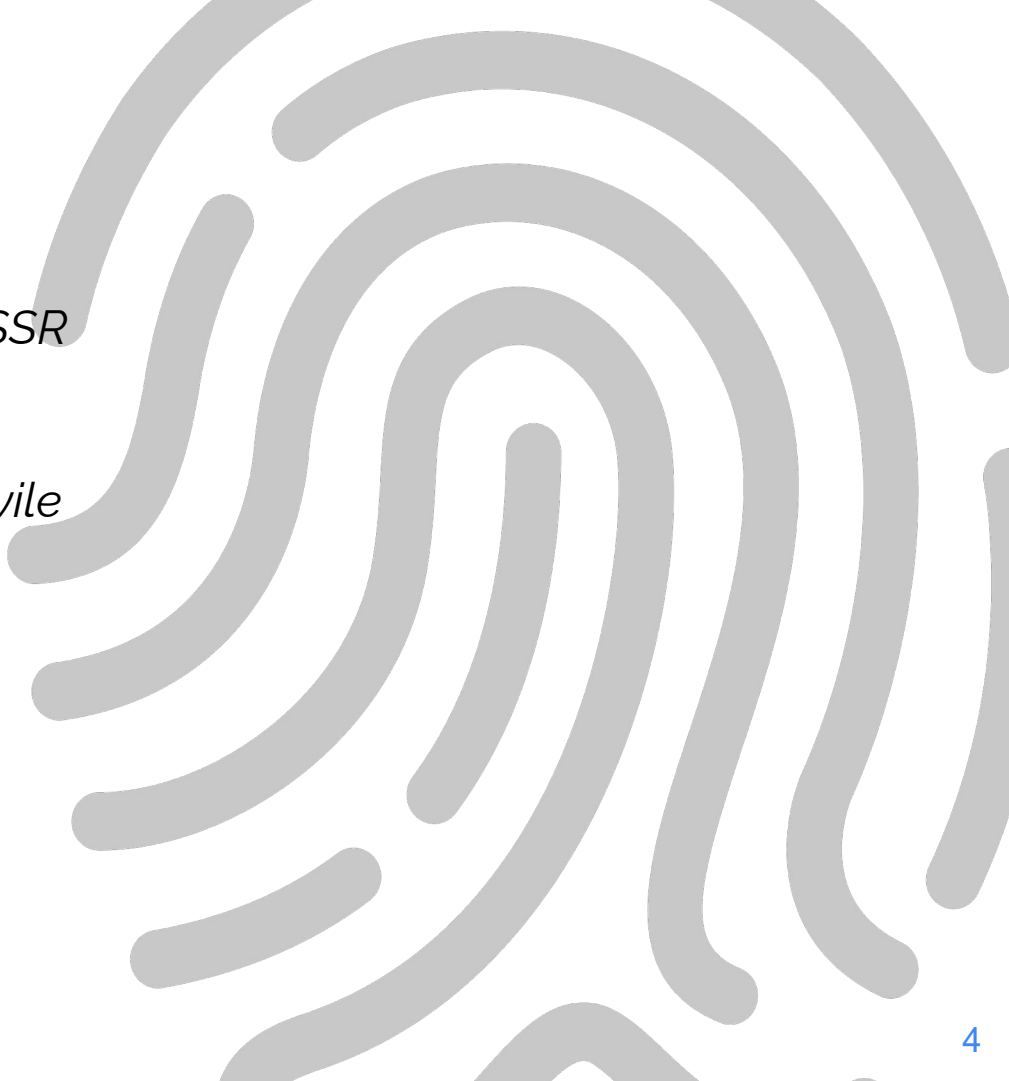


*Comment concilier respect de la vie privée et
sécurisation des réseaux informatiques en entreprise ?*



Plan

- 1 - Rappel des responsabilités du TSSR*
- 2 - Le droit et l'informatique*
- 3 - Le lien avec la Responsabilité Civile*
- 4 - Le droit à la vie privée*





Rappel des responsabilités du TSSR



Assurer le bon déroulement des opérations

- *Assurer le bon fonctionnement d'un réseau préexistant ou nouveau*
- *Utiliser les bons paramètres pour une communication idéale entre ordinateurs et périphériques d'un même réseau*
- *Faire l'audit des signaux de bon fonctionnement (débit de transmission/réception des données, temps de réponse que prend un périphérique pour répondre à une requête, etc...) et corriger les erreurs*
- *Comprendre la nature du réseau et en optimiser les composantes pour un rendement optimal*



Optimiser et maintenir la sécurité

- *Assurer la protection des réseaux ainsi que des données qui y transitent*
- *Garantir la sécurité du réseau (ex: pare-feu, mot de passe, ...)*
- *Former les utilisateurs aux bonnes pratiques*



Maintenir la performance logicielle et matérielle à un niveau élevé

- *Prévenir les brèches de sécurité et tentatives d'intrusion*
- *Surveillance de la performance du pare-feu*
- *Gestion proactive des mots de passe et des comptes utilisateurs du réseau*
- *Configuration optimale des logiciels (systèmes d'exploitation et solutions anti-virus)*
- *Mise à niveau du matériel utilisé pour le fonctionnement du réseau*



Gestion des accès et des comptes

- *Comptes utilisateurs correctement configurés*
- *Les accès attribués leur permettent une utilisation dans les limites définies*
- *Il n'y a aucun conflit de cohabitation ou d'accès aux ressources disponibles sur le réseau.*



Veille stratégique et formation continue

- *Veille*
- *Formation continue*



Le droit et l'informatique



Préambule

Les réseaux informatiques et la gestion des données numériques sont des atouts vitaux pour les entreprises.

Les personnels SI sur ces fonctions ont de multiples droits et devoirs légaux.

Les administrateurs d'un système d'information sont assujettis à différents aspects du droit français.



Quelques termes

[RGPD et données personnelles](#)

CNIL : Commission Nationale de l'Informatique et des Libertés. Elle est le régulateur des données personnelles. Elle accompagne les professionnels dans leur mise en conformité et aide les particuliers à maîtriser leurs données personnelles et exercer leurs droits.

RGPD : Règlement Général sur la Protection des Données. Il encadre le traitement des **données personnelles** pour les résidents de l'UE.

Données personnelles : Toute information se rapportant à une personne physique identifiée ou identifiable (nom, prénom, ...)

Charte informatique : document destiné à régir l'utilisation des moyens informatiques mis à disposition des salariés par leur employeur dans une entreprise donnée (doit être présentée au CSE + règlement interieur).



Un article de loi

Loi informatique et libertés (N° 78-17 du 6 janvier 1978 rev. 01/06 2019) :

- *Loi Française*
- *Relative à l'informatique, aux fichiers et aux libertés*
- *Réglemente la liberté de traitement des données personnelles, c'est-à-dire la liberté de ficher les personnes humaines.*



Un deuxième

Droit à l'oubli ou à l'effacement (*article 17 du RGPD*) :

- *Loi Européenne*
- *Accorde au citoyen de l'UE un droit à l'effacement de ses données personnelles*

Exceptions :

- *Exercice du droit à la liberté d'expression et d'information*
- *Respect d'obligation légale (ex. délai de conservation de facture = 10 ans)*
- *Utilisation des données si elles concernent un intérêt public dans le domaine de la santé, à des fins de recherche scientifique, historique ou à des fins statistiques*
- *De l'exercice ou de la défense de droits en justice.*



Un dernier !

Droit au respect de la vie privée (art. 9 alinéa 1 du code civil) :

- *Loi Française*
- « Chacun a droit au respect de sa vie privée » et donc personne ne peut s'immiscer dans ce domaine contre le gré de l'intéressé.

Interdiction :

- *Découter, enregistrer, ou transmettre sans le consentement des paroles prononcées à titre privé ou confidentiel*
- *Publier le montage réalisé avec les paroles ou l'image d'une personne sans son consentement*

⇒ Sanctions au niveau **pénal**



Schéma du droit de la Sécurité des Systèmes d'Information (2015)

Lien

17



Ai-je le droit de ne pas savoir ?

Au sein d'un SI, ou en autonomie, ces métiers ont des accès privilégiés sur les réseaux, les systèmes, et les données.

Ces données peuvent relever de :

- La **vie privée résiduelle des utilisateurs**
- Leurs **données personnelles**
- Leurs **données relevant de la propriété intellectuelle**, etc.

Toutes ces notions sont encadrées d'un point de vue juridique.

*Vous n'êtes pas un spécialiste du droit, ni juriste, ni avocat, mais **vous ne pouvez ignorer votre responsabilité** !*



Outils juridiques

On peut s'appuyer sur des outils pour s'aider au quotidien.

Par ex :

- *Une charte informatique*
- *Une charte de l'utilisateur*
- *Une connaissance concrète de la chaîne fonctionnelle*
- *Les données de CLUF*
- *Les mentions légales de sites web*
- *Site cybermalveillance.gouv.fr*



Ai-je le droit de ...

Communiquer le mot de passe d'un utilisateur à son manager, la direction, etc. ?

⇒ **NON**

Les mots de passe sont des données personnelles. Ils permettent de savoir ce qu'un utilisateur donné a pu faire sur le réseau de l'entreprise (art.5 RGPD et CNIL).

⇒ *Sauf si :*

L'employeur justifie que le salarié détient sur son poste « des informations nécessaires à la poursuite de l'activité de l'entreprise et qu'il ne peut accéder à ces informations par d'autres moyens. »

Avec courrier/mail de la direction/RH ⇒ RAZ mot de passe



Ai-je le droit de ...

Lire le contenu d'un dossier/fichier/mail avec l'indication "personnel" ?

⇒ **NON**

Tout fichier, ..., identifié comme "personnel" est présumé privé, même sur un poste de travail professionnel (juris. Cours de cassation et CNIL).

⇒ *Sauf si :*

- *Consentement explicite de l'utilisateur (demande écrite, salarié présent, ...)*
- *Risque pour l'entreprise (Cour de Cassation du 17/06/2009) ([Lien](#))*
- *Instruction pénale, décision de justice*

⇒ *Avec courrier/mail de la Direction/RH => NON*

*Attention à vos **clauses de confidentialité** !*



Ai-je le droit de ...

Lire les mails des utilisateurs qui n'ont pas "personnel" en objet ?

⇒ **OUI**

Tout fichier créé, envoyé ou reçu depuis le poste de travail est de nature professionnelle et par conséquent peuvent être consultés par l'employeur.

⇒ Mais ...

Accès dans un but légitime (RGPD et CNIL).

Pour le salarié : préciser explicitement les fichiers (...) de nature privée.

*Attention à vos **clauses de confidentialité** !*



Ai-je le droit ...

En l'absence d'un utilisateur, et sur la demande de son manager, de modifier son message d'absence sur sa messagerie ?

⇒ **NON**

*Modifier le message d'absence impose l'accès à la messagerie du salarié.
Interdit sans son accord !*

⇒ *Sauf si :*

- *Possibilité de faire l'action sans ouvrir la messagerie (console Exchange 365)*
- *Accord écrit Direction/RH*
- *Action définie dans la charte informatique*
- *Utilisateur informé à son retour (RGPD , CNIL)*

*Attention à vos **clauses de confidentialité** !*



Ai-je le droit de ...

Copier des données utilisateurs dans le cadre d'une sauvegarde de données ?

⇒ **OUI**

Dans le cadre d'une maintenance, d'une politique de sauvegarde, d'un MCO (Maintien en Conditions Opérationnelles).

⇒ *Mais*

- *Données personnelles protégées*
- *Durée de rétention des sauvegarde limité*
- *Utilisateurs informés (art. 13 RGPD)*

*Attention à vos **clauses de confidentialité** !*



Le lien avec la Responsabilité Civile



La responsabilité civile

Articles du Code Civil.

Focus sur 3 articles : 1382, 1383, et 1384.

Depuis l'ordonnance du 10 février 2016 : 1240, 1241, 1242.

Amène dans l'IT les 3 actions suivantes :

- *Inform*
- *Contrôler*
- *Agir*



Lien entre la RC et l'IT

Article 1240 du CC : Responsabilité pour faute.

«Tout fait quelconque de l'homme, qui cause à autrui un dommage, oblige celui par la faute duquel il est arrivé, à le réparer »

Article 1241 du CC : Responsabilité pour imprudence ou négligence

«Chacun est responsable du dommage qu'il a causé, non seulement par son fait, mais encore par sa négligence ou par son imprudence »

Article 1242 du CC : Responsabilité du fait d'autrui

«On est responsable non seulement du dommage que l'on cause par son propre fait, mais encore de celui qui est causé par le fait des personnes dont on doit répondre, ou des choses que l'on a sous sa garde... »



Informer

Conseil "**renforcé**" :

- *Alerte = Danger avéré => Permet d'informer d'un problème bien défini, connu et réel*
- *Mise en garde = Risque potentiel => Permet de signaler la possibilité d'un problème (hypothétique ou probable).*

S'applique à 3 domaines :

- *Le nucléaire*
- *La chimie de type « SEVESO »*
- **L'informatique !**



Informers (suite)

Les utilisateurs doivent être informés des données archivées, de la durée de rétention, de coupure réseau ou d'interruption de service.

*Les mots-clés **Information**, **alerte**, **conseil**, ou **mise en garde** dans un rapport, un mail, ou sur l'intranet peuvent vous aider en cas de contentieux.*

⇒ *D'un point de vue juridique, on doit pouvoir prouver que **l'information a été transmise**.*

*Ce qui compte, c'est la **preuve d'information** (log, mail, message intranet...).*



Contrôler

Contrôler, c'est prévenir les fautes ou négligences (art. 1241) en surveillant l'usage des ressources.

Le contrôle du réseau se fait en traçant et analysant les données et les ressources.

Les bonnes pratiques pour la détection de fonctionnements anormaux (ex):

- *Centraliser et paramétrer la conservation des journaux systèmes pour une durée légale. Exemple en France, avec le RGPD, durée de 1 an*
- *Obtenir des statistiques sur l'utilisation des services, le débit utilisé, les sites consultés, l'espace disque, etc.*
- *Mettre en place des sondes de monitoring*



Contrôler (suite)

*En cas de constat de pratique illicite ou non conforme, un dossier doit être constituer pour attester de cette illégalité. L'employeur sera prévenu **sans toutefois avoir connaissance du contenu.***

*Tout contenu suspect provenant d'informations personnelles **ne peut être remis qu'à un OPJ habilité ou à un tribunal.***

⇒ D'un point de vue juridique, on doit démontrer que l'entreprise a mis en place des moyens de prévention adaptés à ses obligations légales.



Agir

*En cas de crise (PCA, PRA) ou d'urgence, vous avez le droit et le devoir **d'agir** pour assurer la **continuité du service**, de même que le droit de **refuser** des demandes qui mettraient le SI en danger.*

Ne pas hésiter à rappeler à l'ordre ceux qui n'appliquent pas les règles établies.

*La sécurité du SI doit être assurée **en tout temps et tout lieux**.*

ex : un correctif de sécurité n'a pas été passé et cela a amené un incident grave.

*Pour ne pas être responsable, il faudra **prouver** que l'on était absent (RH) et qu'il n'y avait pas de redondance humaine (planning SI).*



Agir (suite)

L'anticipation des problèmes à venir doit faire partie de votre quotidien.

*Retenez les termes **vigilance**, **perspicacité** et **discernement** !*

⇒ D'un point de vue juridique, on doit démontrer que l'entreprise a pris les mesures nécessaires face à un risque ou un incident.



Comment apporter des preuves ?

Sur les systèmes actuels, tout est archivé et journalisé.

*Prouver = démontrer que l'on n'est pas dans le cadre de la **négligence fautive**, autrement dit, de pouvoir prouver que l'on applique bien les bonnes pratiques, le bon protocole, le bon MO.*

Garder des traces :

- *Historique de messagerie (alerte, conseils, recommandation, ...)*
- *Main courante, wiki, où les actions sont tracés*
- *Rapports d'activité*



Ai-je le droit de ...

Éteindre/redémarrer un serveur applicatif/infrastructure en cas d'infection virale sans prévenir les utilisateurs hors SI ?

⇒ **OUI**

Pour des raisons de sécurité du SI (art. 32 du RGPD, ANSSI).

Remarques :

- *Prévenir les administrateurs SI*
- *Prévenir la direction*
- *Prévenir les utilisateurs (dès que possible)*



Ai-je le droit de ...

Supprimer des données utilisateurs qui ne correspondent pas à la charte informatique ?

⇒ **OUI**

Remarques :

- *Si la charte informatique (signée par l'utilisateur), interdit explicitement certains usages ou fichiers*
- *Avoir une trace écrite de l'action effectuée*
- *Prévenir l'utilisateur concerné, éventuellement sa hiérarchie*



Ai-je le droit de ...

D'enregistrer des données du réseau sans prévenir les utilisateurs pour des raisons de sécurité ?

⇒ **OUI**

Remarques :

- Ces enregistrements doivent être indiqué dans la charte informatique
- Ils doivent être anonymisés (CNIL)
- Correspondre à une politique de journalisation (art. 5 et 13 RGPD)



Ai-je le droit de ...

Donner des informations d'utilisation, de contenu, de visite de sites d'un utilisateur à la demande de sa hiérarchie ?

⇒ **NON**

Ce sont des données personnelles (au sens du RGPD) => Atteinte à la vie privée

Exceptions :

- *En réalité, l'employeur peut consulter les logs de navigation (sites consultés) à condition d'avoir informé le salarié (charte) et que cela ne soit pas une surveillance constante et déloyale*
- *Ou demande par un tribunal ou un OPJ => seuls habilités à faire cette demande*



Je dois ...

Prévenir obligatoirement ma hiérarchie d'un problème de sécurité même si je sais qu'il ne sera pas résolu pour des problèmes budgétaires, de manque de personnel, de manque de compétence ?

⇒ **OUI**

Obligation de signalement :

- *Bonnes pratiques de cybersécurité (ANSSI)*
- *Principe de responsabilité (art. 32 RGPD)*
- *Devoir de loyauté du salarié (art. L1222-1 Code du Travail)*

Remarques : *Avoir une trace écrite de l'action effectuée.*

En cas de problème avéré, on doit amener la preuve que l'information a été transmise.



D'après-vous ...

En cas de faute de votre part, c'est l'entreprise qui est responsable à votre place ?

⇒ **NON**

Pour information, en droit du travail, l'employeur est responsable des actes de ses salariés dans le cadre de leur fonction (art. 1242 du CC)

MAIS :

- *Faute lourde ou action en dehors prérogatives => responsabilité personnelle du salarié*
- *Salarié responsable de ses actes => Attention à la négligence pro.*



Le droit à la vie privée



Deux points de vue

Du côté de l'entreprise:

L'employeur souhaite protéger les intérêts de son entreprise en :

- *protégeant la fuite des informations stratégiques,*
- *prévenant l'apparition de virus*
- *empêchant la circulation de contenus illicites sur le réseau*

Du côté des salariés :

- *Revendication du droit à une vie privée sur leur lieu de travail (connexion internet, dossiers avec contenu personnel)*

La CNIL a reconnu un **droit à la vie privée au travail**.



La responsabilité du TSSR

Il doit :

- *Assurer la sécurité du réseau, tout en respectant les données personnelles des salariés couvertes par le secret des correspondances et par le droit à la vie privée*
- *Encadrer et limiter l'usage d'internet :*
 - *Droit de contrôle et de surveillance des salariés*
 - *Attention aux principes du droit à la vie privée !*
- *Agir en toute transparence*
- *Assurer la confidentialité des données même vis-à-vis de la hiérarchie*



La responsabilité du TSSR (suite)

- *Obligation de notifier la CNIL en cas de violation de données (fuite de données) sous 72h (Art. 33 RGPD) => responsabilité à connaître pour alerter la hiérarchie immédiatement*



En conclusion

- *Bien différencier données professionnelles et personnelles*
- *Ce n'est pas parce que vous pouvez le faire techniquement que vous avez le droit de le faire*

[Veille juridique \(2014\)](#)